

Imam Mahmudi

PT Finnet Indonesia

Cyber Academy

Format Laporan	
Nama Lab	Authentication – LAB 1
Issue	SQL Injection, Sanitasi Input, Hashing password
Mitigasi	1. Menggunakan prepare statement / binding 2. Hasing password 3. Validasi Input 4. Ratelimit
Link Github	
Sample Penerapan Secure Code 1. Validasi input<pre>if (!filter_var(\$email, FILTER_VALIDATE_EMAIL)) { \$_SESSION['error_message'] = "Format email tidak valid."; header('Location: ' . \$host . '/authentication/lab-1/'); exit; }</pre> 2. Menggunakan prepare statement<pre>\$stmt = \$conn->prepare("SELECT username, password FROM users WHERE email = ?"); \$stmt->bind_param("s", \$email); \$stmt->execute();</pre> 3. Verify password bcrypt / hashing<pre>if (\$user && password_verify(\$password, \$user['password'])) {</pre>	

Format Laporan	
Nama Lab	Authentication – LAB 2
Issue	SQL Injection, Sanitasi
Mitigasi	1. Prepared Statement untuk mencegah SQL Injection 2. Validasi dasar untuk nomor telepon 3. Penanganan kesalahan yang lebih aman 4. Ratelimit
Link Github	
Penerapan secure coding 1. Validasi notelp<pre>if (!preg_match('/^[0-9]{10,15}\$/', \$phoneNumber)) { \$_SESSION['error_message'] = "Format nomor handphone tidak valid"; header('Location: ' . \$host . '/authentication/lab-2/'); exit; }</pre>	

2. Penerapan prepare statement

```
$stmt = $conn->prepare("SELECT id, phone_number FROM users WHERE  
phone_number = ?");  
$stmt->bind_param("s", $phoneNumber);  
$stmt->execute();
```

Format Laporan	
Nama Lab	Authentication – LAB 3
Issue	SQL Injection, Sanitasi
Mitigasi	1. Sql Injection 2. Sanitasi Input 3. Otorisasi user otp 4. Ratelimit
Link Github	
Penerapan Secure Coding	
1. Sanitasi input	
<pre>if (!preg_match('/^[0-9]{4,10}\$/', \$otp) !preg_match('/^[0-9]{10,15}\$/', \$phoneNumber)) { \$_SESSION['error_message'] = "Format OTP atau Nomor HP tidak valid"; header('Location: ' . \$host . '/authentication/lab-2/otp.php'); exit; }</pre>	
2. Penerapan prepare statement dan cek otp otorisasi user di db	
<pre>\$query = " SELECT users.username FROM otp JOIN users ON users.id = otp.user_id WHERE otp.otp = ? AND users.phone_number = ? "; \$stmt = \$conn->prepare(\$query); \$stmt->bind_param("ss", \$otp, \$phoneNumber); \$stmt->execute();</pre>	

Format Laporan	Fileupload
Nama Lab	Fileupload – LAB 1
Issue	SQL Injection, Sanitasi
Mitigasi	1. Otorisasi token / session 2. Sql Injection 3. Allowed mime type
Link Github	
Penerapan Secure Coding	
1. Validasi access cookie	
<pre>if (!\$cookieValue !preg_match('/^[a-f0-9]{32}\$/', \$cookieValue)) { \$avatar = ""; }</pre>	
2. Penerapan preparestatement	
<pre>\$stmt = \$conn->prepare("</pre>	

```

SELECT p.avatar
FROM access_login al
JOIN profiles p ON al.user_id = p.user_id
WHERE al.token = ?
LIMIT 1
");
$stmt->bind_param("s", $cookieValue);
$stmt->execute();
$result = $stmt->get_result();

```

3. Allowed mime type upload file

```

$allowedTypes = ['image/jpeg', 'image/png', 'image/gif'];
$fileType = mime_content_type($tmpName);

if (!in_array($fileType, $allowedTypes)) {
    $message = "File harus berupa gambar (jpeg/png/gif)";
    header('Location: ' . $host . '/file-upload/lab-1/index.php?message=' . urlencode($message));
    exit();
}

```

4. Reformat namefile

```

$safeFileName = uniqid('avatar_') . '_' . basename($fileName);
$targetPath = $directory . $safeFileName;

```

5. Update profile menggunakan prepare statement

```

$updateStmt = $conn->prepare("UPDATE profiles SET avatar = ? WHERE user_id = ?");
$updateStmt->bind_param("si", $avatar, $idUser);
if ($updateStmt->execute()) {
    $message = "Data profile berhasil diupdate";
} else {
    $message = "Gagal mengupdate profile";
}

```

Format Laporan	Fileupload
Nama Lab	Fileupload – LAB 2
Issue	SQL Injection, Sanitasi
Mitigasi	4. Otorisasi token / session 5. Sql Injection
Link Github	
Penerapan Secure Coding	

Format Laporan	Idor
Nama Lab	Lab 1
Issue	1. SQL Injection, Sanitasi
Mitigasi	1. Otorisasi token / session 2. Sql Injection

	3. Validasi input
Link Github	
Penerapan Secure Coding	
<pre> if (!\$cookieValue !preg_match('/^[a-f0-9]{32}\$/', \$cookieValue)) { ... die("Token tidak valid atau tidak ada."); } \$stmt = \$conn->prepare(" ... SELECT s.saldo ... FROM access_login al ... JOIN saldo s ON al.user_id = s.user_id ... WHERE al.token = ? "); \$stmt->bind_param("s", \$cookieValue); \$stmt->execute(); \$result = \$stmt->get_result(); </pre>	

Format Laporan	Idor
Nama Lab	Lab 2
Issue	SQL Injection, Sanitasi
Mitigasi	1. Otorisasi token / session 2. Sql Injection 3. Encryption menggunakan hashing
Link Github	
Penerapan Secure Coding	
1. Validasi session <pre> if (!isset(\$_SESSION['user_id'])) { ... die("Unauthorized access"); } </pre> 2. Hashing password <pre> // Gunakan password_hash (bukan sha1) \$hashedPassword = password_hash(\$password, PASSWORD_BCRYPT); </pre>	

Format Laporan	Idor
Nama Lab	Lab 3
Issue	SQL Injection, Sanitasi
Mitigasi	1. Valiasi query path id 2. Sql Injection
Link Github	
Penerapan Secure Coding	

```

//Pastikan ID ada dan valid
if (!$userID || !is_numeric($userID)) {
    ...die("Invalid user ID");
}

$stmt = $conn->prepare("SELECT * FROM users WHERE id = ?");
$stmt->bind_param("i", $userID); // 'i' untuk integer
$stmt->execute();

$result = $stmt->get_result();
$row = $result->fetch_assoc();

```

Format Laporan	LFI
Nama Lab	Lab 1
Issue	SQL Injection, Sanitasi
Mitigasi	1. Validasi yang boleh di akses 2. Path menggunakan absolute path 3. Menggunakan prepare statement
Link Github	

Penerapan Secure Coding

```

$validFiles = ['file1.php', 'file2.php', 'file3.php'];

if (in_array($file, $validFiles)) {
    ...$filePath = "../../assets/gallery/lab-1/{$file}";

    ...//Pastikan file tersebut adalah file yang diharapkan
    ...if (file_exists($filePath) && is_file($filePath)) {
        ...include($filePath);
    } else {
        ...die("File tidak ditemukan");
    }
} else {
    ...die("File tidak valid");
}

```

Format Laporan	SQL Injection
Nama Lab	Lab 1
Issue	SQL Injection, Sanitasi
Mitigasi	1. Menggunakan prepare statement 2. Validasi input
Link Github	
Penerapan Secure Coding	

```

$category = isset($_GET['category']) ? $_GET['category'] : null;
if ($category == null) {
    $sql = "SELECT p.id, p.name, p.price, p.thumbnail, pc.category_name
    FROM products p
    JOIN product_categories pc ON pc.id = p.product_category_id
    WHERE p.is_publish = true";
    $stmt = $conn->prepare($sql);
    $stmt->execute();
} else {
    $category = htmlspecialchars($category, ENT_QUOTES, 'UTF-8');

    $sql = "SELECT p.id, p.name, p.price, p.thumbnail, pc.category_name
    FROM products p
    JOIN product_categories pc ON pc.id = p.product_category_id
    WHERE pc.category_name = ? AND p.is_publish = true";

    // Prepare the statement
    $stmt = $conn->prepare($sql);
    $stmt->bind_param("s", $category); // "s" means string
    $stmt->execute();
}

```

Format Laporan	SQL Injection
Nama Lab	Lab 2
Issue	SQL Injection, Sanitasi
Mitigasi	1. Menggunakan prepare statement 2. Validasi input 3. Validasi session
Link Github	

Penerapan Secure Coding

1. Menggunakan prepare statement

```

$queryToken = "SELECT u.username
FROM users u
JOIN access_login al ON al.user_id = u.id
WHERE al.token = ?";
$stmt = $conn->prepare($queryToken);
$stmt->bind_param("s", $cookieValue); // Bind token ke query
$stmt->execute();
$resultQueryToken = $stmt->get_result();

```

2. Validasi query path

```

$category = htmlspecialchars($category, ENT_QUOTES, 'UTF-8');

$sql = "SELECT p.id, p.name, p.price, p.thumbnail, pc.category_name
FROM products p
JOIN product_categories pc ON pc.id = p.product_category_id
WHERE pc.category_name = ? AND p.is_publish = true";

```

Format Laporan	XSS
Nama Lab	Lab 1
Issue	SQL Injection, Sanitasi
Mitigasi	1. Menggunakan prepare statement 2. Validasi input 3. Validasi session

Link Github

Penerapan Secure Coding

1. Menggunakan prepare statement

```
...// Use prepared statements for security
...$queryToken = "SELECT u.username, u.id, p.avatar
...FROM users u
...JOIN access_login al ON al.user_id = u.id
...JOIN profiles p ON p.user_id = u.id
...WHERE al.token = ?";

...$stmt = $conn->prepare($queryToken);
...$stmt->bind_param("s", $cookieValue); // Bind token parameter
...$stmt->execute();
...$resultQueryToken = $stmt->get_result();
```

2. Validasi xss

```
...// Prevent XSS by encoding the output
...$fullname = htmlspecialchars($fullname, ENT_QUOTES, 'UTF-8');
```